

SESSION 1 · CASE STUDY · 20-MINUTE GUIDED LAB

Stop the ₹48 Lakh Fraud

Investigating a Suspicious Email Communication Using Free Browser-Based Tools

MISSION: Decide whether Meridian Industries should release the payment - and defend your decision with evidence.

Duration	Level	Installation
20 minutes	Beginner-friendly	None

Important safety rule

Use only the synthetic evidence provided in this activity. Never paste confidential, personal, legally privileged, or real case evidence into a public website. VirusTotal submissions and searches may be retained or visible to other users.

1. What You Will Analyse

You will examine a simulated Business Email Compromise (BEC) message. BEC is a form of social engineering in which an attacker impersonates a trusted executive, supplier, or colleague to persuade a victim to transfer money or disclose sensitive information.

Your investigation must answer five questions:

- ☐ Identity: Does the message really come from the claimed CFO?
- ☐ Authentication: Did the message pass SPF, DKIM, and DMARC checks?
- ☐ Routing: Which systems handled the message, and what does the header reveal?
- ☐ Behaviour: Does the language use urgency, secrecy, authority, or control bypass?
- ☐ Decision: Should the payment be approved, rejected, or paused pending more evidence?

Investigation schema

1. Preserve	2. Read	3. Authenticate	4. Correlate	5. Decide	6. Report
Keep original artefacts	Body + addresses	SPF/DKIM/DMARC	Header + context	Risk verdict	Evidence-based rationale

Timing plan

Time	Mission	Output
0-2 min	Read the incident and preserve the evidence pack	Initial hypothesis
2-6 min	Inspect message body and addresses	Behavioural red flags
6-11 min	Analyse full header	SPF/DKIM/DMARC + route
11-14 min	Hash the evidence text in CyberChef	Integrity demonstration
14-17 min	Review registration/reputation evidence	Corroboration
17-20 min	Issue verdict and 30-second briefing	Final decision

2. Before You Begin: Email Authentication in Plain Language

SPF - Sender Policy Framework

Checks whether the server sending the message is authorised by the domain shown in the envelope sender / Return-Path.

Question: Did the message come through an approved sending server?

Caution: SPF can pass for a malicious domain. It does not prove that the visible From name is honest.

DKIM - DomainKeys Identified Mail

Adds a cryptographic signature to selected message headers and body content. The receiver checks that signature using a public key published in DNS.

Question: Was the signed content unchanged, and did the signing domain authorise the signature?

Caution: DKIM can be absent, fail because of modification, or pass for an attacker-controlled domain.

DMARC - Domain-based Message Authentication, Reporting and Conformance

Checks whether SPF or DKIM passes and aligns with the visible From domain. The domain owner can publish a policy such as none, quarantine, or reject.

Question: Does an authenticated identity align with the domain the user sees?

Caution: A DMARC pass lowers spoofing risk but does not guarantee that the message is benign.

Simple analogy

SPF	DKIM	DMARC
Is this an authorised post office?	Is the parcel seal intact?	Does the sender's identity align, and what should the receiver do?

3. Evidence Pack

All names, domains, addresses, and IPs below are synthetic and reserved for training. Do not replace them with real case data.

Exhibit A - Incident Brief

Meridian Industries

Monday, 20 July, 14:02. Priya Nair, Finance Manager, receives an email that appears to come from CFO Anil Mehta. It requests an immediate transfer of ₹48,00,000 to a new vendor before 3 PM. The CFO is travelling and reportedly cannot take calls. Priya pauses and sends the message to IT Security. You are the investigator.

Exhibit B - Message as Received

From: "Anil Mehta, CFO" <a.mehta@rneridian-industries.example>
Reply-To: anil.mehta.cfo.office@gmail.example
To: priya.nair@meridian-industries.example
Date: Mon, 20 Jul 2026 14:02:11 +0530
Subject: URGENT - Confidential wire transfer

Priya,

I am in meetings with the acquisition partners and cannot take calls. We must complete a confidential payment of Rs 48,00,000 to our new vendor Apex Component Traders before 3 PM today, or we lose the contract penalty clause.

This is highly sensitive - do not discuss with anyone in the office until the announcement. Process it under 'miscellaneous procurement' and confirm to me on this email only. I am counting on you to handle this personally.

Sent from my iPhone
Anil

Exhibit C - Full Synthetic Header

Return-Path: <bounce@mail-relay77.example>
Received: from mail-relay77.example (mail-relay77.example [203.0.113.45])
by mx.meridian-industries.example with ESMTPS id 7F2A91
for <priya.nair@meridian-industries.example>;
Mon, 20 Jul 2026 14:02:11 +0530
Received: from unknown (HELO srv12) [198.51.100.27]
by mail-relay77.example with SMTP;
Mon, 20 Jul 2026 08:31:44 +0000
Authentication-Results: mx.meridian-industries.example;
spf=fail smtp.mailfrom=bounce@mail-relay77.example;
dkim=none (message not signed);
dmarc=fail header.from=rneridian-industries.example
Message-ID: <a91x@mail-relay77.example>
From: "Anil Mehta, CFO" <a.mehta@rneridian-industries.example>

Reply-To: anil.mehta.cfo.office@gmail.example

To: priya.nair@meridian-industries.example

Date: Mon, 20 Jul 2026 14:02:11 +0530

Subject: URGENT - Confidential wire transfer

MIME-Version: 1.0

Content-Type: text/plain; charset=UTF-8

4. Free Tools and What Each One Does

Tool	Use in this lab	Link	Privacy rule
Google Admin Toolbox - Messageheader	Parses SMTP headers and visualises mail routing.	https://toolbox.googleapps.com/apps/messageheader/	Paste only the synthetic header.
CyberChef	Computes SHA-256 and demonstrates evidence integrity.	https://gchq.github.io/CyberChef/	Use only synthetic text or training files.
ICANN Lookup (RDAP)	Shows current public domain registration data.	https://lookup.icann.org/en	Use the safe practice domain listed below.
VirusTotal Search	Searches existing reports for domains, IPs, URLs, and file hashes.	https://www.virustotal.com/gui/home/search	Do not upload confidential files or submit private URLs.
MXToolbox SuperTool	Checks public DNS, MX, SPF, and DMARC records.	https://mxtoolbox.com/SuperTool.aspx	Use only public or training domains.

Why the case domain will not resolve

The case uses the reserved .example namespace so no real organisation is targeted. Live DNS, RDAP, and reputation tools may correctly return no result. For those steps, you will first practise the interface with example.com, then interpret a supplied simulated evidence card for the fictional case.

5. Step-by-Step Investigation

Mission 1 - Preserve and Form a Hypothesis (0-2 minutes)

1. Do not reply, forward externally, click links, open attachments, or contact the sender using details in the message.
2. Keep the original message and full header together as one evidence item.
3. Read Exhibits A and B once. Write an initial hypothesis; this is provisional, not a verdict.

Initial hypothesis:

Mission 2 - Find Human and Address Red Flags (2-6 minutes)

Inspect the visible message before using a tool. Tick each indicator you can support from Exhibit B.

- ☐ Urgent deadline or financial pressure
- ☐ Secrecy / instruction not to consult colleagues
- ☐ Authority or personal pressure
- ☐ Request to bypass normal procurement or payment controls
- ☐ Reply only through the suspicious channel
- ☐ Look-alike sender domain: “rn” visually imitates “m”
- ☐ Reply-To differs from the visible From address
- ☐ Unreachable executive used to block out-of-band verification

Strongest behavioural indicator and why:

Mission 3 - Analyse the Header (6-11 minutes)

Open [Google Admin Toolbox - Messageheader](#).

1. Copy the complete text in Exhibit C, beginning with Return-Path and ending with Content-Type.
2. Paste it into the large header input box.
3. Select the button labelled “Analyze the header above” or the equivalent analyse action.
4. Review the parsed route and the raw Authentication-Results line. The synthetic header may not produce every graphical field because the domains are reserved; the raw header remains authoritative for this exercise.
5. Read the Received fields from bottom to top. The bottom-most Received line is the earliest visible hop.

Field	Your finding	What it suggests
SPF		
DKIM		
DMARC		
From domain		
Reply-To domain		
Return-Path / Message-ID domain		
Earliest visible IP		

Decision rule:

Authentication failures are evidence of risk, not a complete verdict. Correlate them with domain mismatches, routing, language, and business context.

Mission 4 - Prove Evidence Integrity with SHA-256 (11-14 minutes)

Open [CyberChef](#).

- Paste this exact sentence in the Input pane: Transfer Rs 48,00,000 today.
- In the Operations search box, type SHA2.
- Drag SHA2 into the Recipe pane.
- Set Size = 256 and leave Rounds = 64. This produces SHA-256.
- Copy the 64-character hexadecimal output into the first line below.
- Change only one digit: Transfer Rs 48,00,001 today.
- Compare the second output with the first.

Original SHA-256:

Modified SHA-256:

Did one character change the entire hash?

Can the hash show which character changed?

What does a matching hash before and after analysis demonstrate?

Mission 5 - Learn Domain Registration and DNS Tools (14-17 minutes)

Because the case domain is deliberately fictional, use example.com only to learn where the tools display their fields. Do not interpret example.com as malicious.

- A. Open [ICANN Lookup](#), enter example.com, and identify: registrar, creation date (if displayed), nameservers, and status.
- B. Open [MXToolbox SuperTool](#), enter example.com, and run MX Lookup or DNS Lookup. Note which public records exist.
- C. Open [VirusTotal Search](#), search example.com, and locate the domain report tabs. Do not submit or rescan anything.

Now interpret the supplied simulated case evidence card:

Simulated case evidence	Finding
Domain	rneridian-industries.example (look-alike of meridian-industries.example)
Registration age	3 days before the message
Public MX/SPF/DMARC	No stable corporate configuration observed
Threat-intelligence context	No prior detections - absence of detection is not proof of safety
Investigator interpretation	New + look-alike + authentication failures + payment pressure = high-risk cluster

Important interpretation rule:

A clean or unknown VirusTotal result does not mean safe. New phishing infrastructure may have no history. Likewise, privacy-redacted registration data is not proof of maliciousness.

Mission 6 - Final Decision and 30-Second Briefing (17-20 minutes)

Choose one verdict:

- ☐ APPROVE PAYMENT
- ☐ PAUSE - NOT ENOUGH EVIDENCE
- ☐ REJECT AND ESCALATE AS SUSPECTED BEC

Complete the evidence matrix:

Evidence class	Finding	Reliability	Effect on verdict
Visible addresses	_____	High / Med / Low	_____
SPF/DKIM/DMARC	_____	High / Med / Low	_____
Header route	_____	High / Med / Low	_____
Language/behaviour	_____	High / Med / Low	_____
Domain context	_____	High / Med / Low	_____
Business process	_____	High / Med / Low	_____

Your 30-second investigator briefing (claim + three strongest facts + recommended action):

Immediate response actions

- ☐ Do not release the payment.
- ☐ Verify the request using a known, independent contact channel.
- ☐ Preserve the original email, full header, gateway logs, mailbox audit logs, and any attachment.
- ☐ Search the organisation for messages from the same sender, Reply-To, domain, subject, IP, or Message-ID pattern.
- ☐ Block the look-alike domain and related indicators after validation.
- ☐ If money was transferred, contact the bank and report promptly through the appropriate cybercrime channel.

6. Scoring

Finding	Points	Awarded
Look-alike domain	10	_____
Reply-To mismatch	10	_____
SPF failure	10	_____
DKIM absent	10	_____
DMARC failure	10	_____
Earliest route/IP identified	10	_____
Urgency + secrecy + process bypass	10	_____
Correct SHA-256 method	10	_____
Evidence-based BEC verdict	10	_____
Clear response recommendation	10	_____

Score bands: 90-100 Lead Investigator • 70-89 Senior Analyst • 50-69 Junior Analyst • Below 50 Re-open the case.